LẨN TRÁNH IDS, FIREWALL, HONEYPOT

Môn học: Hệ thống phát hiện xâm nhập mạng

Thành viên:
- Đỗ Phú Ninh
- Nguyễn Quang Huy
- Nguyễn Văn Khiên

Danh sách thiết bị sử dụng trong bài

- Windows Server 2019
- Windows 10
- Firewall pfSense 2.8.1, bao gồm Snort 2.9.20_8, Suricata 7.0.11
- 1 máy Parrot Security
- 1 máy Ubuntu 24.04, cài đặt Docker, Git

CÁC KỸ THUẬT LẨN TRÁNH IDS

Mặc dù IDS ngăn chặn các nỗ lực xâm nhập bảo mật mạng, nhưng kẻ tấn công vẫn có thể trốn tránh IDS bằng các kỹ thuật lẩn tránh

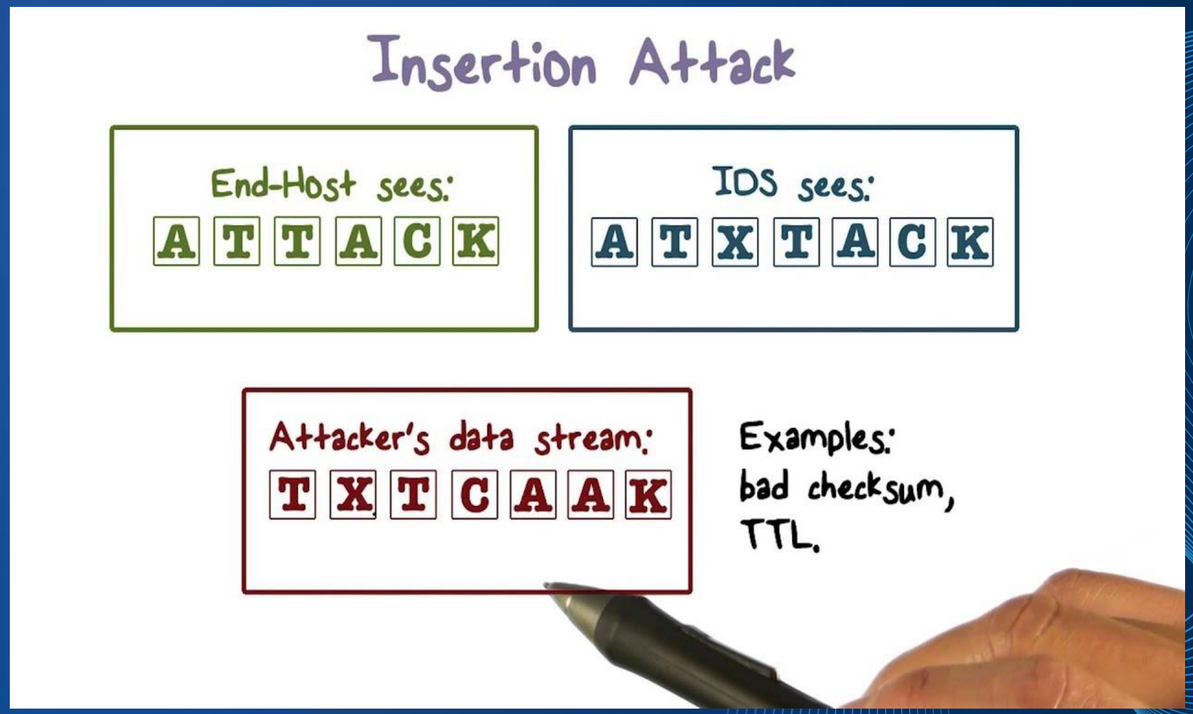
Mục tiêu: vô hiệu hoá khả năng phát hiện hoặc làm cho IDS hoạt động sai lệch

Tấn công chèn (Insertion Attack)

Cơ chế: Kẻ tấn công gửi các gói tin mà IDS chấp nhận nhưng máy đích loại bỏ khi xử lý

Mục đích: Khiến IDS tái dựng luồng dữ liệu khác với dữ liệu mà máy đích thực sự tiếp nhận

Ảnh hưởng: IDS có thể phân tích nhầm nội dung, gây ra cảnh báo sai hoặc bỏ sót hành vi tấn công

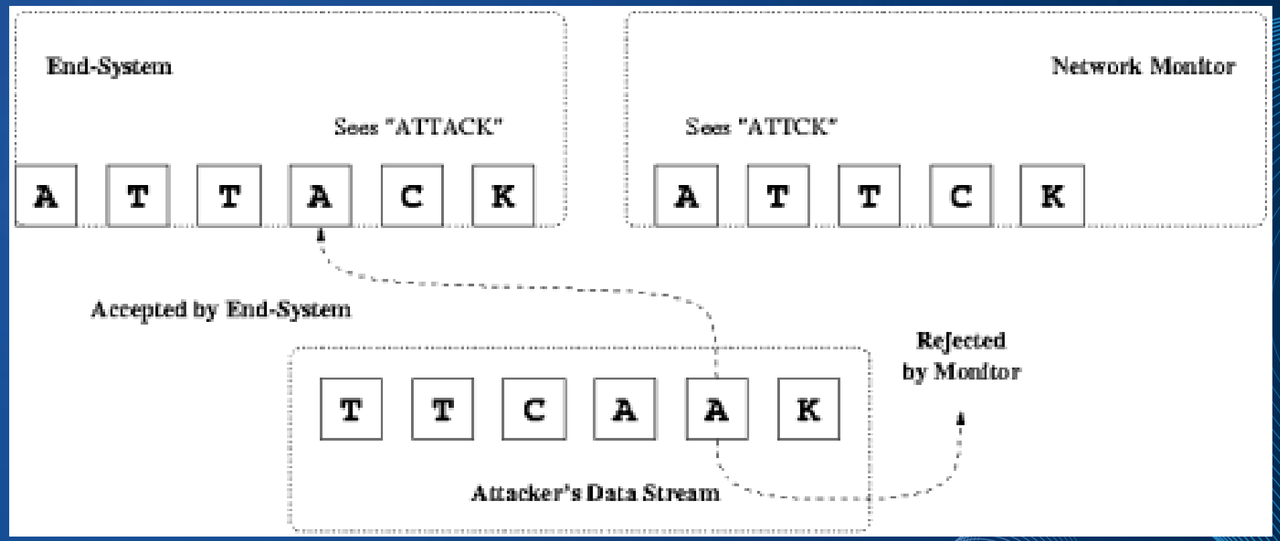


Tấn công trốn tránh (Evasion Attack)

Cơ chế: Gửi các gói tin mà máy đích chấp nhận nhưng IDS loại bỏ hoặc diễn giải khác khi tái dựng luồng dữ liệu.

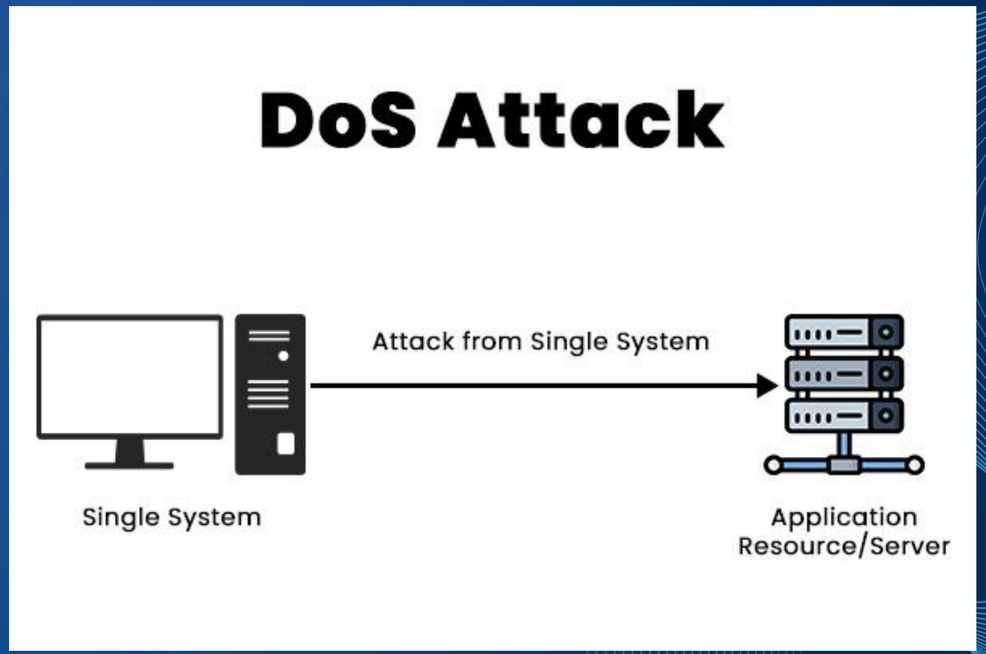
Mục đích: Tạo ra sự khác biệt giữa cách IDS phân tích và cách máy đích xử lý dữ liệu.

Ảnh hưởng: Nội dung tấn công có thể không khớp với luật phát hiện của IDS.



Tấn công từ chối dịch vụ (DoS Attack)

Cơ chế: Gửi liên tục các gói tin từ 01 nguồn làm cho hệ thống không xử lí kịp thời dẫn đến quá tải.
Mục đích: Làm giảm khả năng xử lý lưu lượng hoặc khả năng giám sát của IDS/IPS.
Ảnh hưởng: Hệ thống có thể xử lý chậm, mất gói tin hoặc bỏ lỡ các sự kiện tấn công khác.



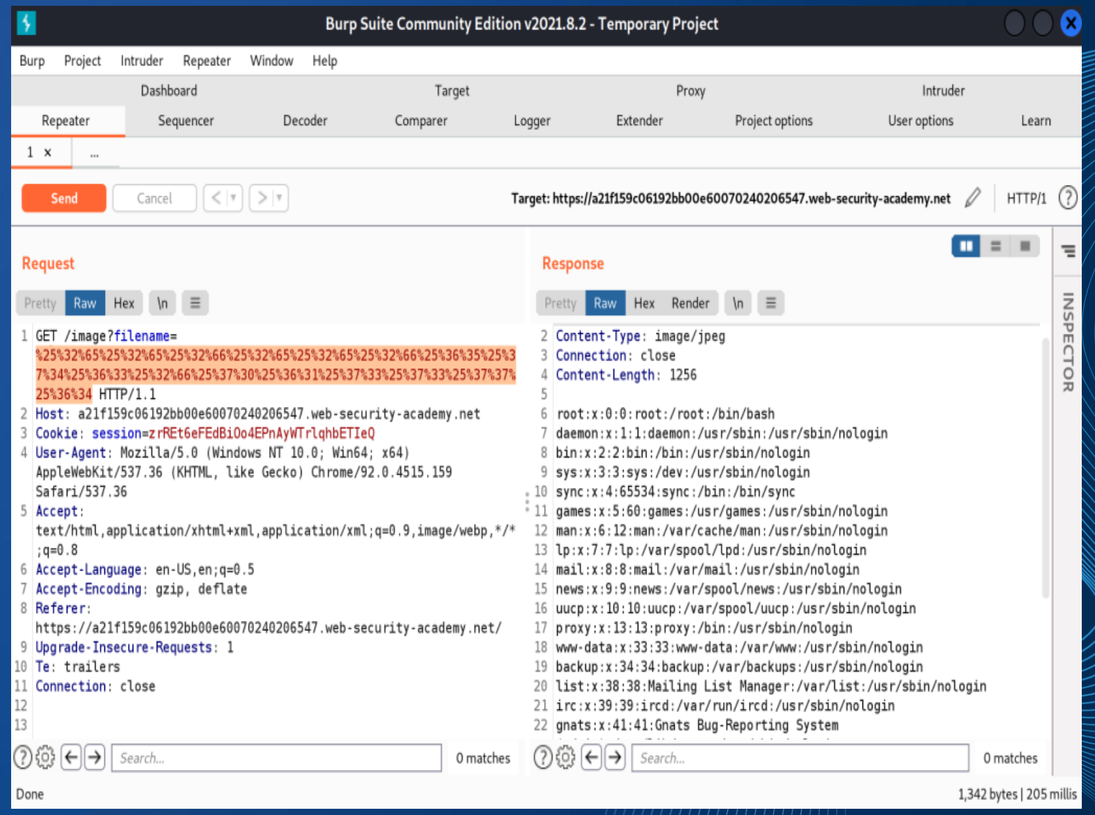
Làm tối nghĩa (Obfuscation)

Cơ chế: Biến đổi cách biểu diễn dữ liệu nhưng giữ nguyên ý nghĩa hoặc hành vi của nội dung, chẳng hạn mã hóa URL hoặc thay đổi cách viết biểu thức.

Mục đích: Khiến nội dung không còn khớp trực tiếp với mẫu nhận diện đơn giản.

Ảnh hưởng: Các luật dựa trên chuỗi ký tự cố định có thể không phát hiện được nội dung đã biến đổi.

Ví dụ:
+ sử dụng kĩ thuật URL Encode trong tấn công Path Traversal biến payload ../../../../etc/passwd thành ..%2F..%2F..%2F..%2Fetc%2Fpasswd
+ sử dụng kĩ thuật URL Encode trong tấn công SQL Injection biến chuỗi admin ‘ -- thành admin%20’%20--



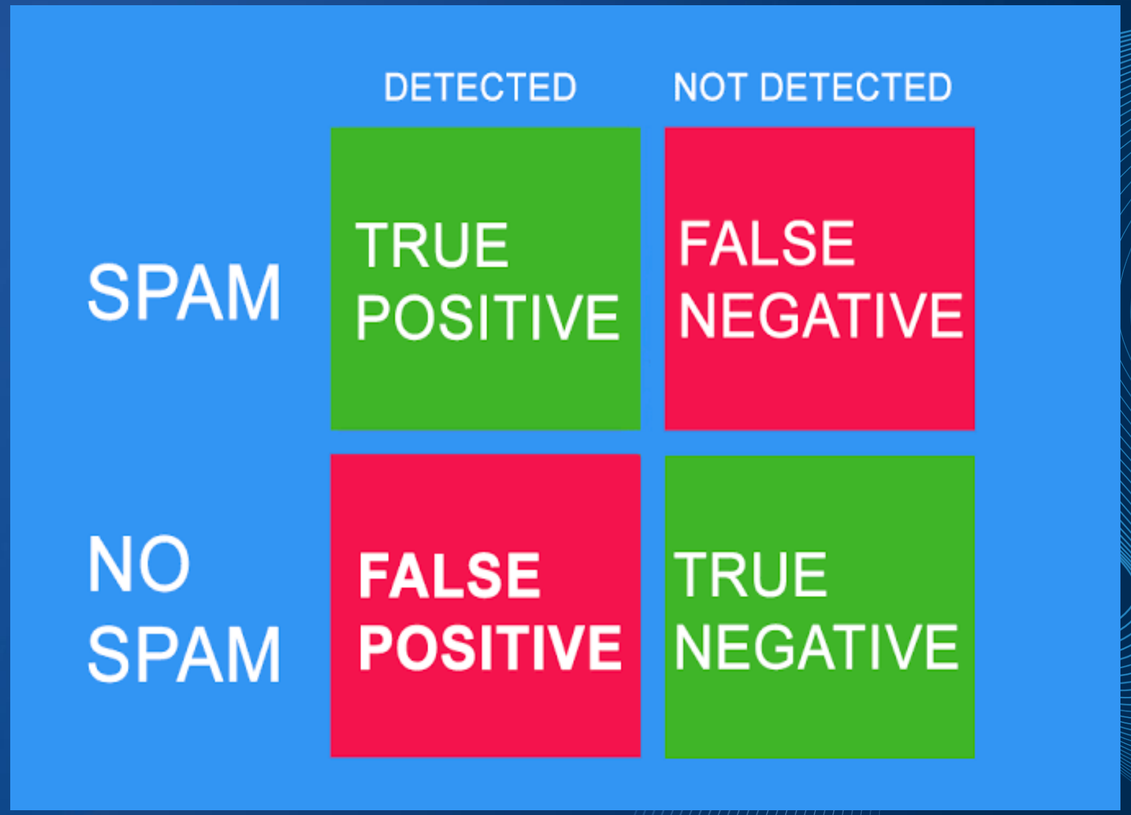
Tạo báo động giả (False Positives)

Cơ chế: Tạo lưu lượng hợp lệ hoặc bất thường có đặc điểm giống các mẫu mà IDS dùng để phát hiện tấn công.

Mục đích: Làm gia tăng số lượng cảnh báo không chính xác.

Ảnh hưởng: Gây nhiễu quá trình giám sát, tăng khối lượng công việc của chuyên viên và khiến cảnh báo thực sự bị bỏ qua.

Ví dụ:
+ 10 thiết bị thực hiện mở 10.000.000 kết nối TCP 3 bước hoàn chỉnh, dẫn đến IDS phát cảnh báo sai
+ rất nhiều người dùng truy cập tại 01 thời điểm trên 01 trang web => cảnh báo phát hiện DDoS sai



Ghép nối phiên (Session Splicing)

Cơ chế: Chia nội dung truyền tải thành nhiều đoạn nhỏ qua một phiên TCP, khiến các gói dữ liệu hoàn chỉnh không xuất hiện trong từng gói tin riêng lẻ.

Mục đích: Kiểm tra khả năng theo dõi phiên và tái dựng luồng TCP của IDS.

Ảnh hưởng: Các luật kiểm tra từng gói độc lập sẽ bỏ sót nội dung, chỉ nhận diện được khi ghép nối toàn bộ luồng.

Ví dụ:
Đối với chuỗi /bin/sh chia ra 2 gói là /bin và /sh\0, nếu như chỉ kiểm tra chính xác chuỗi /bin/sh sẽ bị bỏ qua do không khớp vì /bin và /sh là 2 chuỗi hoàn toàn khác nhau, nếu ghép lại sẽ chính xác

Trốn tránh Unicode (Unicode Evasion)

Cơ chế: Sử dụng các cách biểu diễn Unicode khác nhau cho cùng một ký tự hoặc nội dung tương đương, tùy ngữ cảnh ứng dụng.

Mục đích: Khai thác sự khác biệt trong quá trình giải mã và chuẩn hóa dữ liệu giữa IDS với ứng dụng đích.

Ảnh hưởng: IDS có thể không nhận diện được nội dung nguy hiểm nếu không chuẩn hóa dữ liệu nhất quán.

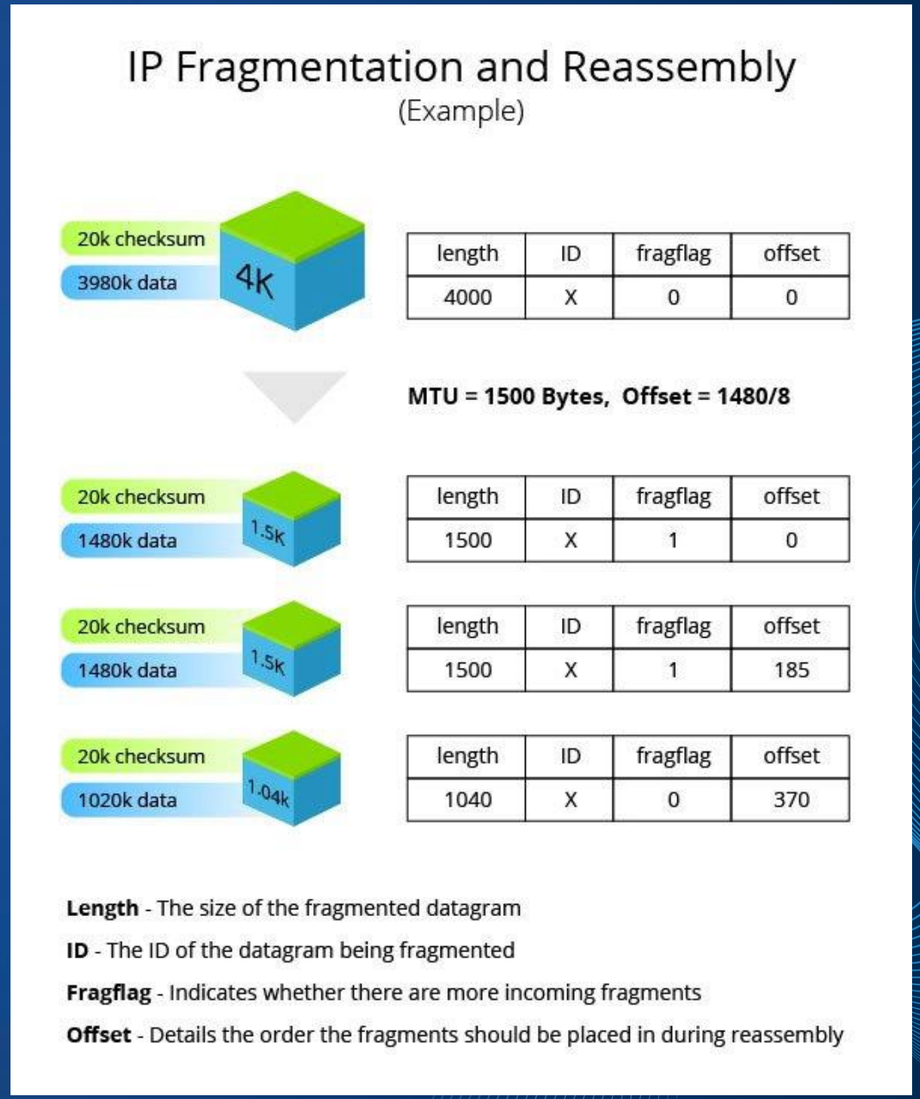
Ví dụ:
Trong tấn công SQL Injection:
admin ‘ -- (\u0061\u0064\u006D\u0069\u006E\u0027\u002D\u002D) biến đổi thành ａｄｍｉｎ’－－ (\uFF41\uFF44\uFF4D\uFF49\uFF4E\uFF07\uFF0D\uFF0D), dẫn đến IDS không nhận dạng đúng và bỏ qua

Tấn công phân mảnh (Fragmentation Attack)

Cơ chế: Chia gói tin thành nhiều mảnh nhỏ trước khi quét cổng dịch vụ.

Mục đích: Kiểm tra khả năng xử lý phân mảnh và tái lắp ráp gói IP của IDS/IPS.

Ảnh hưởng: Nếu quá trình tái lắp ráp không chính xác hoặc không đầy đủ, hệ thống có thể bỏ sót dấu hiệu tấn công



Kịch bản tấn công phân mảnh 1

Nguyên lý: Kẻ tấn công lợi dụng sự khác biệt về thời gian chờ lắp ráp lại các phân mảnh giữa IDS và máy chủ đích.

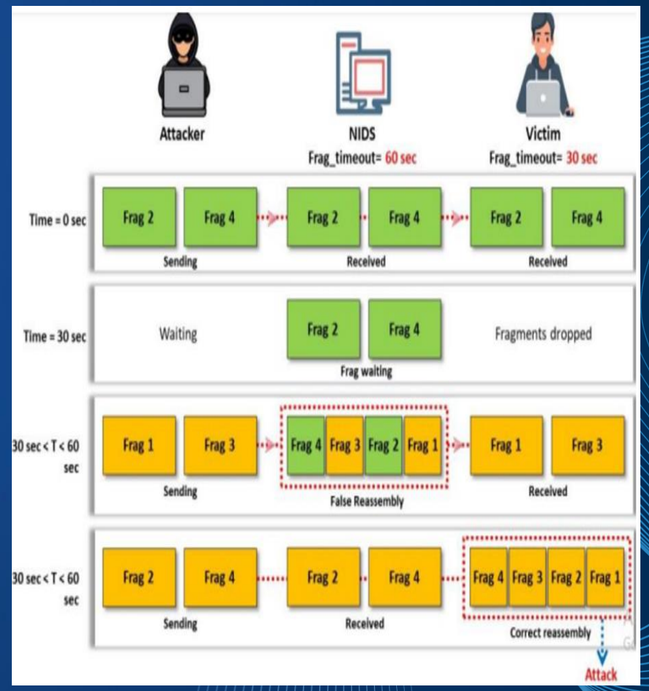
Ví dụ:
Thời gian chờ của IDS: 10 giây.
Thời gian chờ của máy chủ: 20 giây.
Kẻ tấn công gửi phân mảnh tiếp theo sau 15 giây.
IDS hết thời gian chờ và loại bỏ phân mảnh, nhưng máy chủ vẫn tiếp tục chờ và lắp ráp dữ liệu.
Kết quả: Máy chủ nhận được dữ liệu tấn công hoàn chỉnh, trong khi IDS không phát hiện được nội dung độc hại.
Điều kiện thành công: Thời gian chờ lắp ráp của IDS ngắn hơn máy chủ đích.

Kịch bản tấn công phân mảnh 2

Nguyên lý: Kẻ tấn công lợi dụng thời gian chờ lắp ráp của IDS dài hơn máy chủ đích, kết hợp với các phân mảnh có dữ liệu sai và hợp lệ.

Ví dụ:
Thời gian chờ của IDS: 60 giây.
Thời gian chờ của máy chủ: 30 giây.
Kẻ tấn công gửi các phân mảnh sai frag-2', frag-4' trước.
Máy chủ hết thời gian chờ và loại bỏ các phân mảnh chưa đủ để lắp ráp.
Sau đó, kẻ tấn công gửi các phân mảnh hợp lệ. IDS lắp ráp với dữ liệu sai và loại bỏ gói tin do kiểm tra tổng kiểm tra không hợp lệ, trong khi máy chủ có thể lắp ráp các phân mảnh hợp lệ.

Kết quả: Máy chủ có thể nhận được gói tin hoàn chỉnh, nhưng IDS không nhận diện đúng nội dung mà máy chủ xử lý.
Điều kiện thành công: Khác biệt về thời gian chờ, thứ tự phân mảnh và cách xử lý phân mảnh giữa IDS và máy chủ.

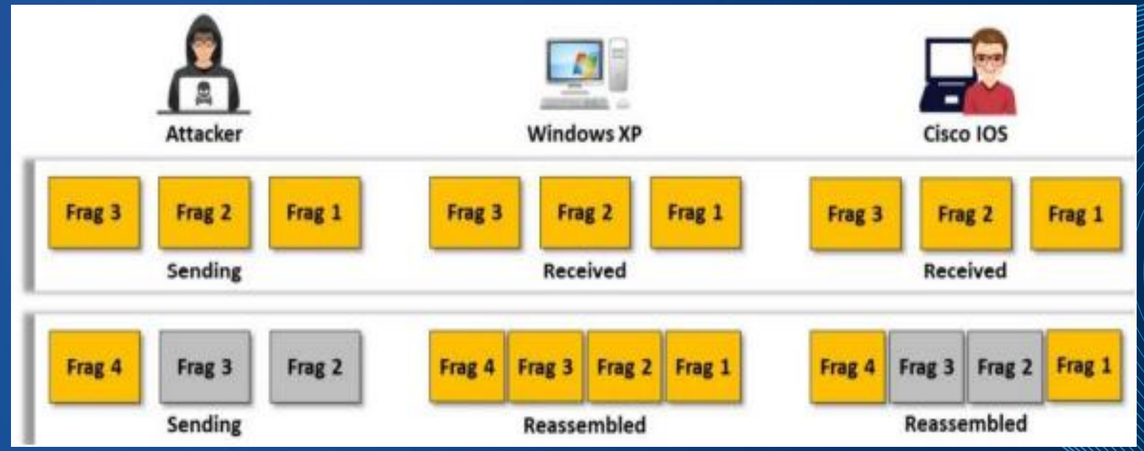


Đoạn mã chồng chéo (Overlapping Fragment)

Cơ chế: Tạo các mảnh với vùng dữ liệu chồng lấn nhau, có thể chứa các byte khác nhau tại cùng vị trí.

Mục đích: Kiểm tra sự khác biệt trong chính sách tái lắp ráp giữa IDS và hệ thống đích.

Ảnh hưởng: Nếu hai hệ thống tái lắp ráp khác nhau, IDS có thể phân tích một nội dung trong khi máy đích nhận nội dung khác.



Cờ khẩn cấp trong TCP

URG (Urgent) là một cờ trong header TCP, dùng để báo rằng gói tin có dữ liệu được đánh dấu khẩn cấp.

Cơ chế: Sử dụng cờ URG và trường Urgent Pointer trong TCP để đánh dấu dữ liệu khẩn cấp.
Mục đích: Kiểm tra sự khác biệt trong cách IDS và hệ điều hành xử lý dữ liệu được đánh dấu khẩn cấp.

Ảnh hưởng: Nếu cách diễn giải dữ liệu khác nhau, nội dung có thể được phân tích không nhất quán. Cờ URG tự nó không phải dấu hiệu chắc chắn của tấn công.

Ví dụ: khi gửi chuỗi dữ liệu là powershell.exe để mở powershell, thông thường IDS sẽ đọc theo thứ tự lần lượt từ trái qua phải so khớp mẫu, nhưng khi có cờ URG thì IDS sẽ đọc không chính xác, vẫn là chuỗi powershell.exe, không biến đổi, không mã hóa, không làm tối nghĩa… làm cho IDS hiểu sai và bỏ qua

Gói RST không hợp lệ

RST là cờ dùng để đặt lại hoặc hủy kết nối TCP.

Cơ chế: Gửi gói TCP có cờ RST với thông tin trạng thái hoặc số thứ tự không phù hợp với phiên kết nối.

Mục đích: Kiểm tra cách IDS xử lý các gói đặt lại kết nối và đồng bộ trạng thái phiên TCP.

Ảnh hưởng: Nếu IDS và máy đích đánh giá tính hợp lệ của gói RST khác nhau, trạng thái theo dõi kết nối có thể bị sai lệch.

Shellcode đa hình

Cơ chế: Biến đổi cách biểu diễn mã khai thác, thường bằng cách mã hóa payload và sử dụng đoạn giải mã, trong khi giữ nguyên hành vi dự kiến.

Mục đích: Tránh các cơ chế phát hiện dựa trên chữ ký byte cố định của mã độc.
Ảnh hưởng: IDS có thể không nhận diện được payload nếu chỉ so khớp mẫu tĩnh mà không phân tích sâu hơn.

Ví dụ về shellcode đa hình:

```
global _start

section .text

_start:

        mov eax, 37
        mov ebx, 0
        sub ebx, 1
        mov ecx, 9
        int 0x80
```

```
global _start

section .text

_start:

        push 37
        pop eax
        push byte -1
        pop ebx
        push byte 9
        pop ecx
        int 0x80
```

ASCII Shellcode

Cơ chế: Biểu diễn mã vỏ bằng các byte thuộc tập ký tự ASCII được phép hoặc có thể hiển thị, thường kết hợp với cơ chế giải mã khi thực thi.

Mục đích: Vượt qua các ràng buộc về ký tự trong một số môi trường khai thác và kiểm thử khả năng nhận diện mã vỏ.
Ảnh hưởng: Các luật chỉ tìm kiếm chuỗi byte đặc trưng có thể không nhận diện được mã vỏ đã được biến đổi.

Ví dụ: shellcode thực thi /bin/sh và setuid về 0 với mục đích tạo root shell với dạng byte hexadecimal:
"\x31\xc0\x31\xdb\x31\xc9\x31\xd2\xb0\xa4\xcd\x80\x31\xc0\xb0\x0b\x51\x68\x2f\x2f\x73\x68\x68\x2f\x62\x69\x6e\x89\xe3\x51\x89\xe2\x53\x89\xe1\xcd\x80“

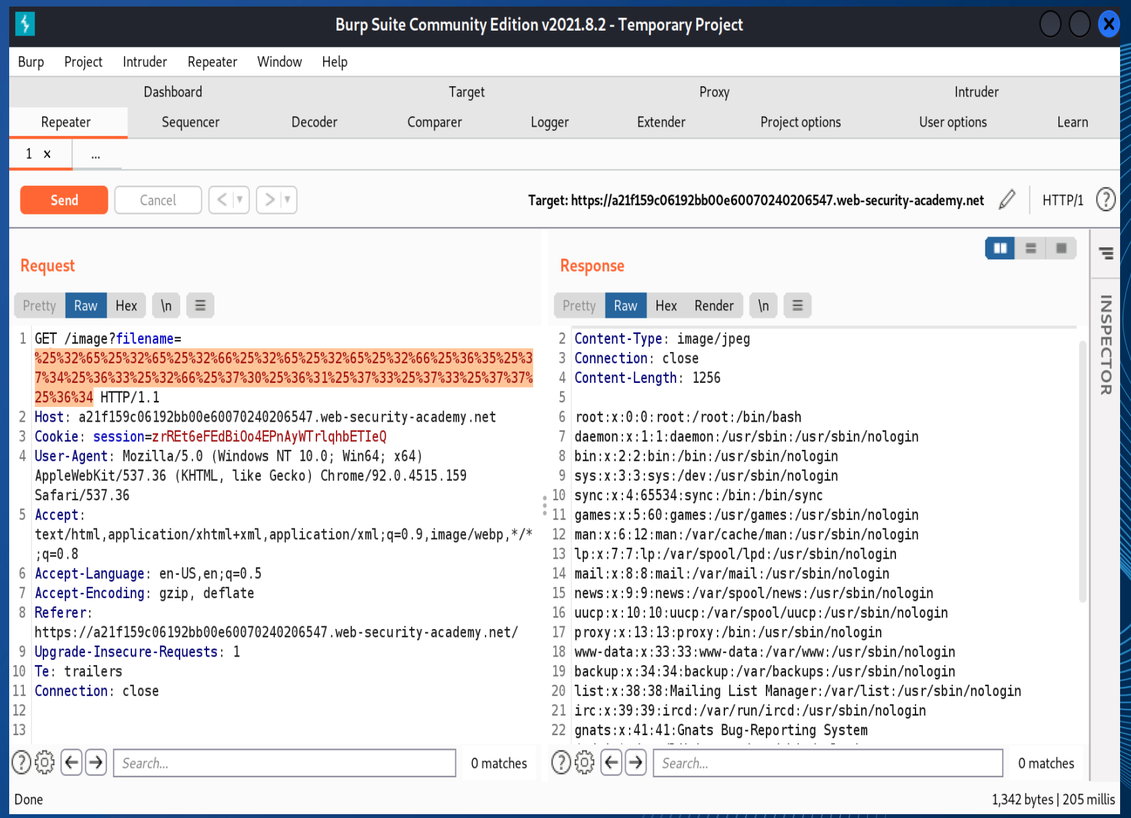
Shellcode đã biến đổi sang dạng ASCII:
“TX-KKKK-KKKK-xjiiP\%0000%AAAA-9%%%-GJJJP-hhNh-th3%-Q6-5P-yyyZ-yZy6-L6---2-8-P-7KKd-%Kdz-%RkzP-xxxx-GGGx-0AFiP-OOOO-jOwO-iaraP-NN%N-a%%a-q44tP-%SS0-%SL5-7uC%P-FkFF-9pUhP-XXXX-XXXX-PXOFP-AAAj-0w2j-0w-vPPPPPPPPPP”

Tấn công lớp ứng dụng

Cơ chế: Khai thác sự khác biệt trong cách phân tích giao thức ứng dụng như HTTP, DNS hoặc SMB: cách xử lý URL mã hóa, header trùng lặp hoặc dữ liệu chia đoạn.

Mục đích: Kiểm thử khả năng phân tích ngữ nghĩa giao thức và chuẩn hóa dữ liệu của IDS/IPS.

Ảnh hưởng: Nếu IDS diễn giải yêu cầu khác với máy chủ ứng dụng, các hoạt động độc hại có thể bị bỏ sót.



Huỷ đồng bộ (Desynchronization)

1. SYN trước khi kết nối

Cơ chế: Kẻ tấn công gửi gói SYN có tổng kiểm tra TCP hoặc số thứ tự không hợp lệ trước khi kết nối được thiết lập.

Mục đích: IDS có thể cập nhật sai số thứ tự, dẫn đến mất đồng bộ với luồng dữ liệu thực tế.

Ảnh hưởng: IDS có thể bỏ sót lưu lượng hợp lệ hoặc dữ liệu tấn công.

2. SYN sau khi kết nối

Cơ chế: Kẻ tấn công gửi gói SYN giả với một kết nối TCP đã thiết lập, sai số thứ tự khiến IDS hiểu sai trạng thái kết nối.

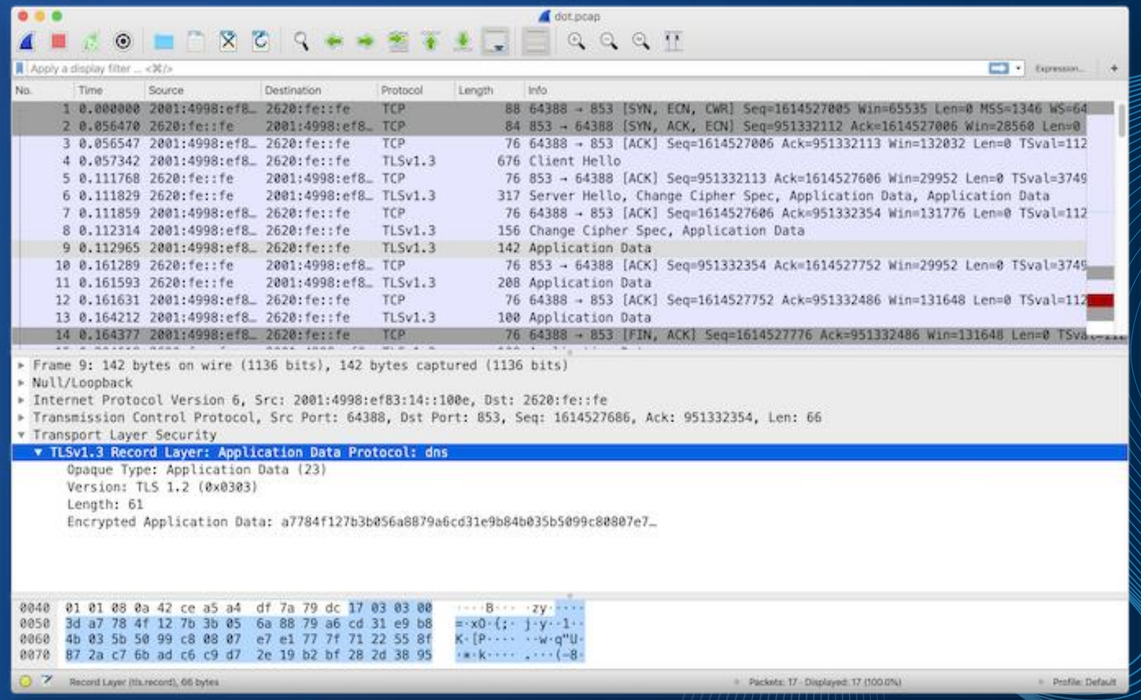
Mục đích: Máy chủ bỏ qua gói SYN, nhưng IDS có thể đồng bộ lại theo số thứ tự giả.

Ảnh hưởng: Kẻ tấn công có thể gửi gói RST để khiến IDS kết thúc trạng thái kết nối của nó.

Các kỹ thuật né tránh khác

Mã hoá: sử dụng DoH (Dns Over HTTPS), TLS hoặc VPN để mã hoá lưu lượng độc hại. IDS không thể phân tích -> bỏ sót

Tràn ngập (Flooding): tạo lưu lượng giả làm cạn kiệt tài nguyên IDS -> bỏ sót lưu lượng tấn công thực sự



CÁC KỸ THUẬT BYPASS TƯỜNG LỬA

Tường lửa hoạt động theo một bộ quy tắc được xác định từ trước. Kẻ tấn công có thể bỏ qua tường lửa bằng cách sử dụng nhiều ký thuật bỏ qua tường lửa khác nhau.

Mục tiêu: đánh lừa tường lửa không lọc lưu lượng truy cập độc hại do kẻ tấn công tạo ra

Quét cổng dễ bỏ quên (Port Scanning)

Cơ chế: Kiểm tra các cổng mạng hay bỏ quên để xác định cổng mở và dịch vụ đang hoạt động.

Mục đích: Tìm dịch vụ có thể khai thác và đánh giá quy tắc lọc của tường lửa.

Ảnh hưởng: Làm lộ các dịch vụ có nguy cơ bị tấn công.

Ví dụ:
FireWall-1 của CheckPoint: TCP 256-259
Proxy Server của Microsoft: TCP 1080, 1745

Firewalking

Cơ chế: Sử dụng giá trị TTL của gói tin và phân tích phản hồi IP để xác định các quy tắc ACL, cổng được phép đi qua tường lửa.

Mục đích: Thu thập thông tin về mạng phía sau tường lửa và xác định các dịch vụ có thể truy cập.

Ảnh hưởng: Làm lộ thông tin về cấu trúc mạng và các quy tắc lọc, hỗ trợ kẻ tấn công tìm đường tiếp cận hệ thống.

Banner Grabbing

Cơ chế: Thu thập thông tin phiên bản và nhà cung cấp dịch vụ từ phản hồi của máy chủ.

Mục đích: Xác định hệ điều hành, phần mềm và phiên bản dịch vụ.

Ảnh hưởng: Hỗ trợ kẻ tấn công tìm lỗ hổng phù hợp.

```
┌─[root@parrot]─[~]
└──╼ #nmap -p25 192.168.10.145 --script banner -T5
Starting Nmap 7.95 ( https://nmap.org ) at 2026-10-12 14:58 UTC
Nmap scan report for 192.168.10.145
Host is up (0.00082s latency).

PORT   STATE SERVICE
25/tcp open  smtp
| banner: 220 WIN-UVIP925BAK2 Microsoft ESMTP MAIL Service, Version: 10.0
|_.17763.1 ready at  Mon, 12 Oct 2026 21:58:41 +0700

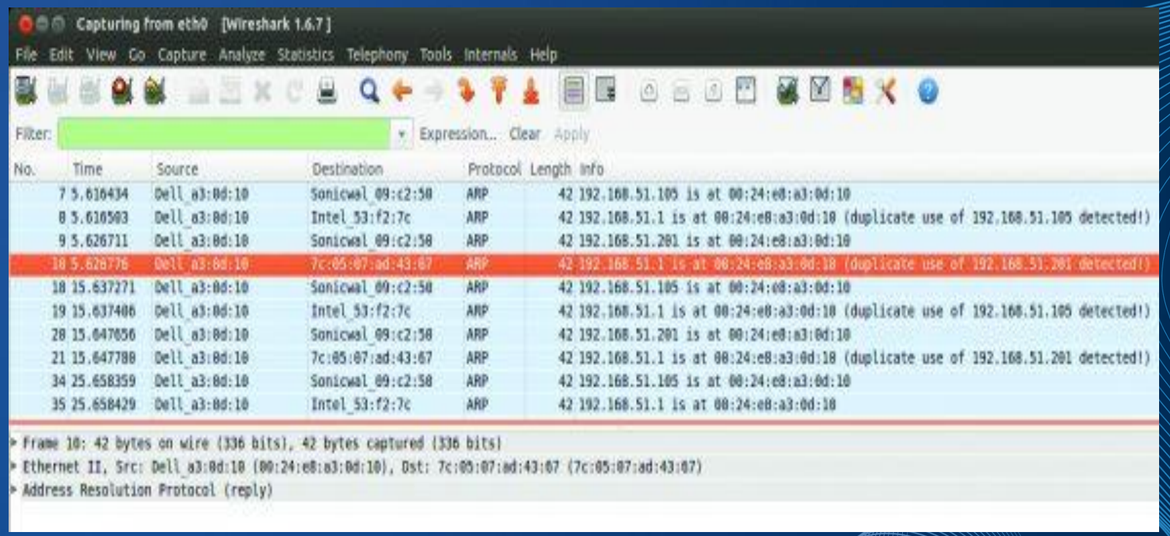
Nmap done: 1 IP address (1 host up) scanned in 0.15 seconds
┌─[root@parrot]─[~]
└──╼ #
```

Giả mạo IP (IP Spoofing)

Cơ chế: Thay đổi địa chỉ IP nguồn trong gói tin thành địa chỉ giả.

Mục đích: Che giấu nguồn gửi hoặc giả danh một máy đáng tin cậy.

Ảnh hưởng: Có thể vượt qua quy tắc lọc dựa trên IP nếu cấu hình không an toàn.

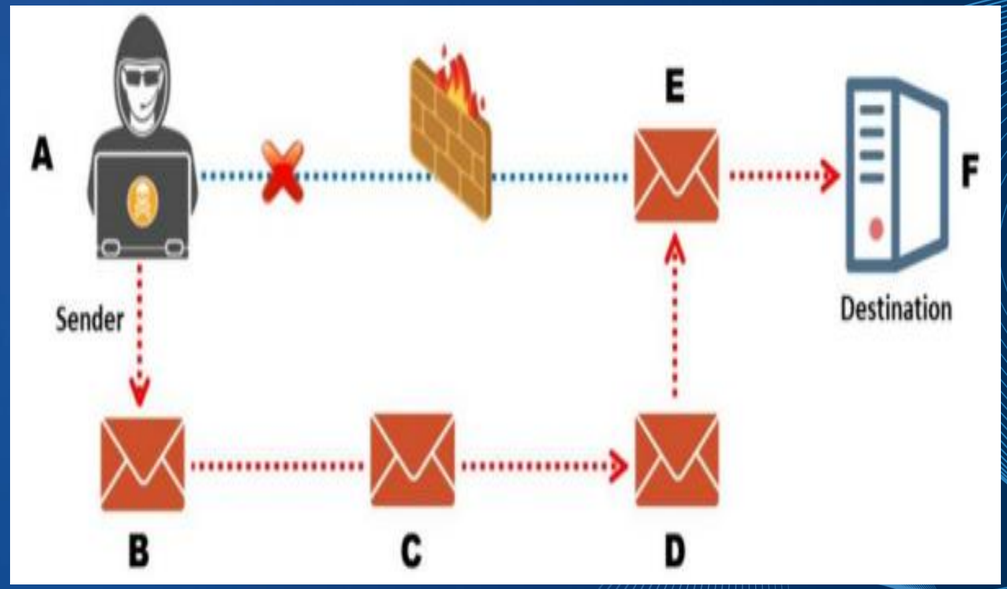


Định tuyến nguồn (Source Routing)

Cơ chế: Chỉ định đường đi của gói tin qua các nút mạng.

Mục đích: Thử lợi dụng cách tường lửa xử lý đường đi của gói tin.

Ảnh hưởng: Có thể làm suy yếu chính sách lọc nếu thiết bị cho phép định tuyến nguồn không an toàn.

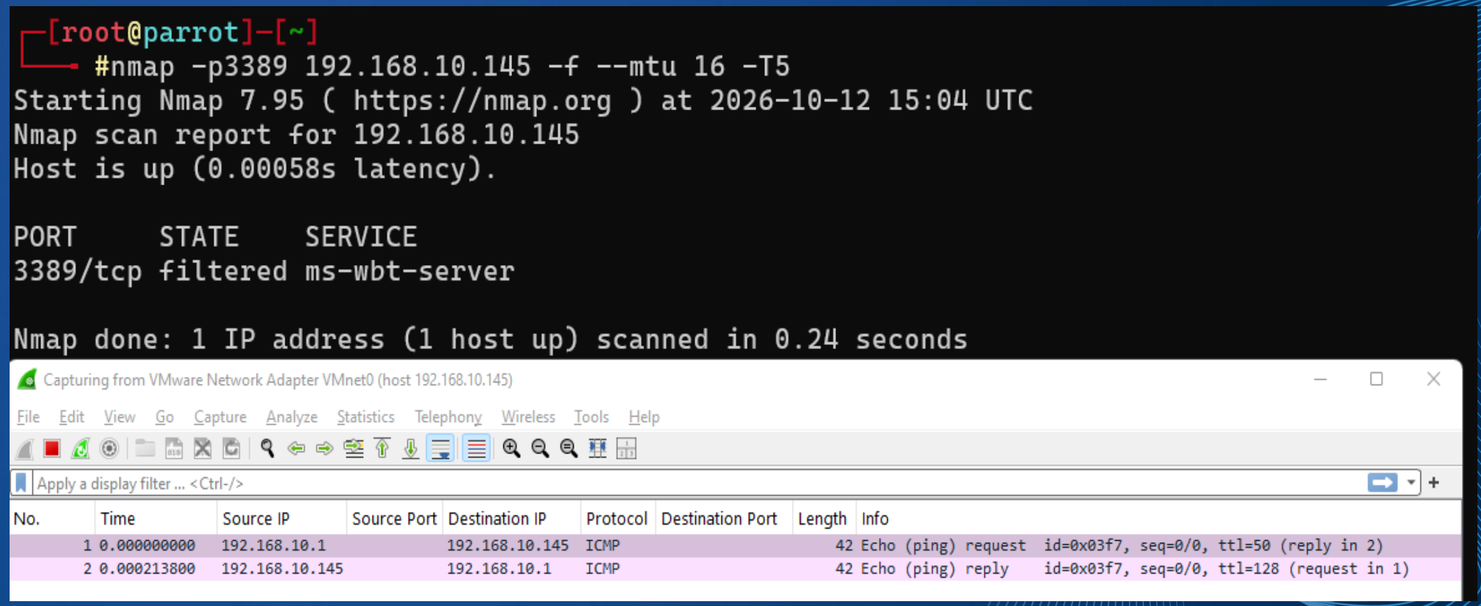


Phân mảnh nhỏ (Tiny Fragments)

Cơ chế: Chia gói IP thành các phân mảnh nhỏ khiến thông tin cần kiểm tra bị tách rời.

Mục đích: Lợi dụng khả năng kiểm tra phân mảnh hạn chế của tường lửa.

Ảnh hưởng: Một số lưu lượng độc hại có thể không bị phát hiện nếu thiết bị xử lý phân mảnh không nhất quán.



Sử dụng địa chỉ IP thay cho URL

Cơ chế: Truy cập máy chủ bằng địa chỉ IP trực tiếp thay vì tên miền.

Mục đích: Thử vượt qua các bộ lọc chỉ dựa trên tên miền hoặc URL.

Ảnh hưởng: Chính sách lọc theo tên miền có thể không áp dụng như dự kiến.

Ví dụ: thay vì google.com => 142.250.197.46

Máy chủ Proxy và trang Web ẩn danh

Máy chủ Proxy

Cơ chế: Chuyển tiếp yêu cầu truy cập thông qua máy chủ trung gian.

Mục đích: Che giấu địa chỉ đích hoặc nguồn truy cập trực tiếp.

Ảnh hưởng: Gây khó khăn cho việc kiểm soát và ghi nhận lưu lượng nếu proxy không được quản lý.

Trang Web ẩn danh

Cơ chế: Truy cập trang web thông qua một dịch vụ trung gian trên Internet.

Mục đích: Truy cập nội dung bị hạn chế bởi chính sách lọc trực tiếp.

Ảnh hưởng: Có thể làm giảm hiệu quả của bộ lọc URL nếu dịch vụ trung gian chưa bị kiểm soát.

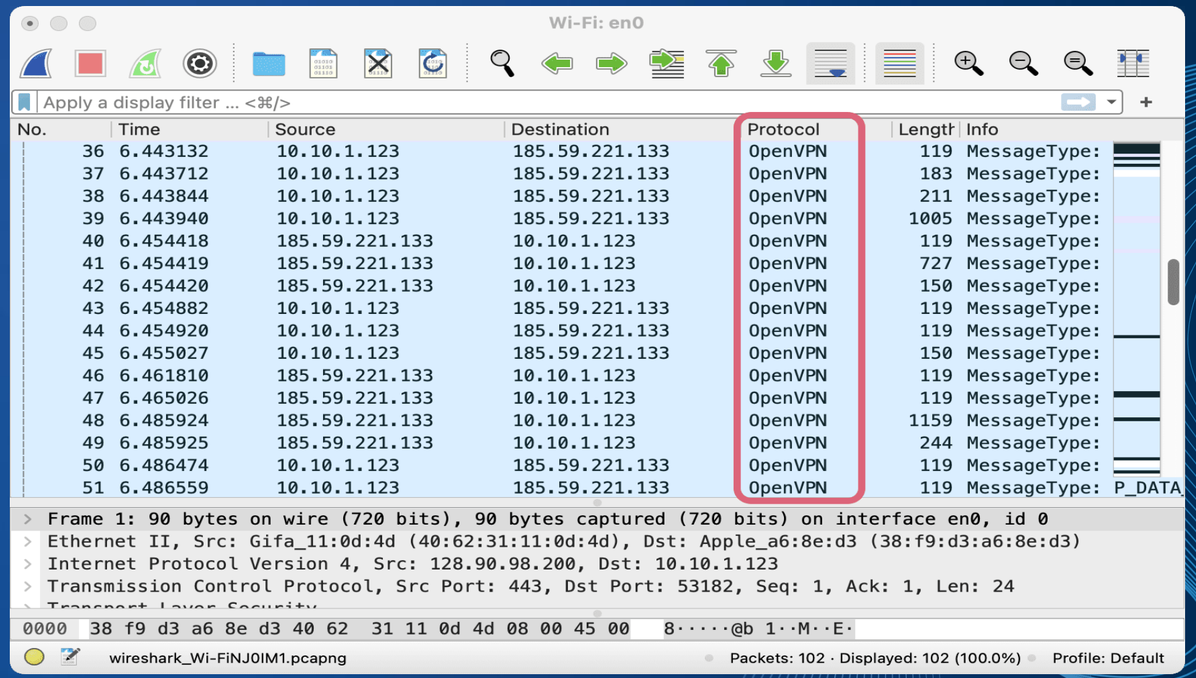
Đường hầm (Tunneling)

Đường hầm: Hiểu như là 1 dạng đóng gói giao thức chính bằng giao thức khác, nói cách khác là VPN

Cơ chế: Truyền dữ liệu thông qua các giao thức như ICMP, TCP ACK, HTTP/HTTPS, SSH và DNS để tạo kênh truyền ẩn.

Mục đích: Vượt qua quy tắc lọc của Firewall, thiết lập kênh trao đổi dữ liệu bí mật.

Ảnh hưởng: Có thể gây rò rỉ dữ liệu, truyền dữ liệu trái phép và gây khó khăn cho việc phát hiện của Firewall nếu không có DPI



Các kỹ thuật khác

- Sử dụng hệ thống bên ngoài: tạo đường giao tiếp ngoài dự kiến, vượt qua các cơ chế kiểm soát mạng
- Tấn công MITM: làm lộ thông tin, thay đổi dữ liệu nếu quá trình giao tiếp không được bảo vệ

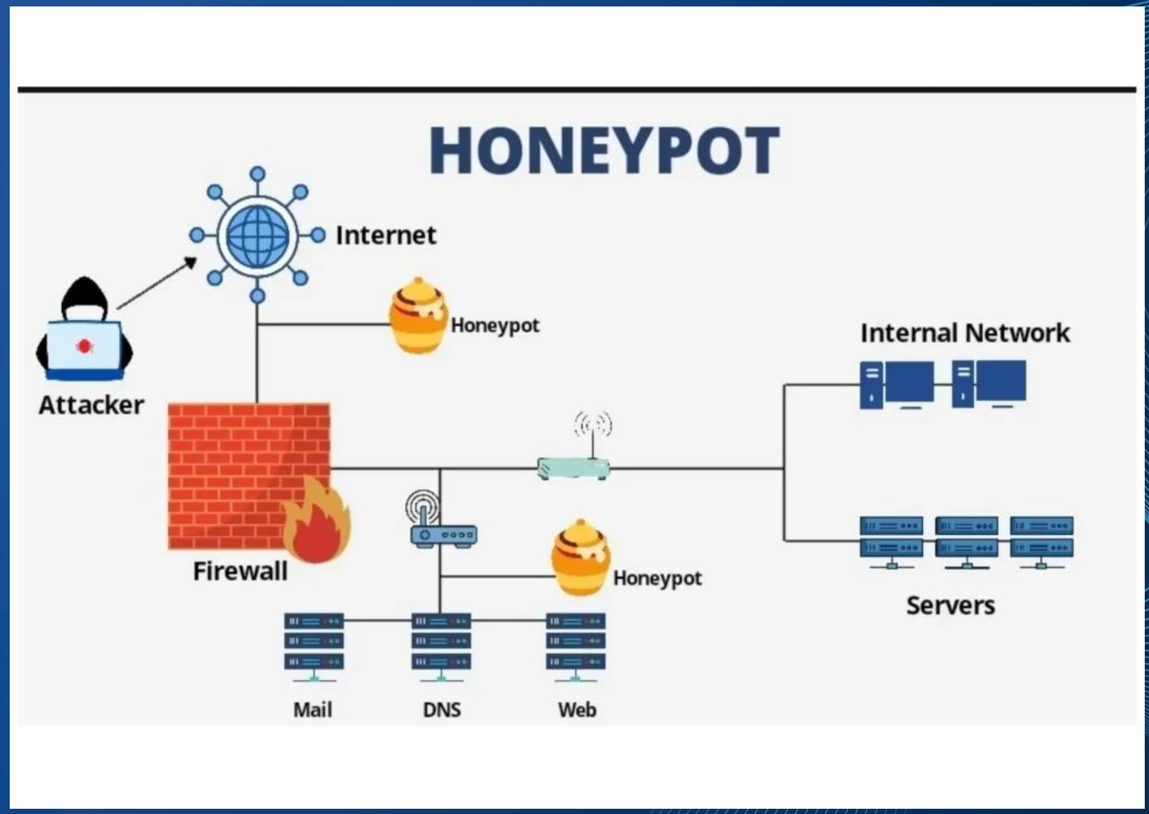
CÁC KỸ THUẬT PHÁT HIỆN HONEYPOT

Giới thiệu Honeypot và phát hiện Honeypot

Honeypot là bẫy được thiết kế để phát hiện, làm chệch hướng hoặc chống lại các nỗ lực xâm nhập trái phép.

Mục đích của kẻ tấn công: phát hiện và bỏ qua honeypot để tránh bị giám sát

Các công cụ phổ biến phát hiện honeypot:
- Send-safe Honeypot Hunter
- kippo_detect



Kỹ thuật phát hiện Tar Pit (Layer 2, 4, 7)

Layer 7 Tar Pit:
- Bẫy ứng dụng (ví dụ: SMTP) phản hồi cực kỳ chậm đối với các lệnh gửi đến.
- Nhận biết: Đo độ trễ (latency/RTT) phản hồi từ dịch vụ.

Layer 4 Tar Pit (ví dụ: LaBrea):
- Chấp nhận kết nối TCP nhưng lập tức hạ TCP Window Size = 0.
- Liên tục gửi ACK giữ kết nối làm cạn kiệt tài nguyên kẻ tấn công.

Layer 2 Tar Pit:
Nhận biết: Phản hồi ARP mang địa chỉ MAC đặc thù 00:00:0f:ff:ff:ff (hoạt động như lỗ đen).

Phát hiện Honeypot trên môi trường ảo hoá

VMware-based Honeypot:
- VMware được dùng phổ biến để dựng Honeypot nhờ khả năng quản lý tài nguyên linh hoạt.
- Nhận biết: Phân tích địa chỉ MAC của card mạng và so sánh với dải MAC đăng ký của VMware Inc (chuẩn IEEE).

Linux User-Mode (UML) Honeypot:
- Phần mềm nguồn mở tạo máy ảo nhẹ để triển khai Honeypot.
- Nhận biết: Kiểm tra các tệp hệ thống đặc thù: /proc/mounts, /proc/interrupts, /proc/cmdline.

Phát hiện Honeyd, Sebek, Snort_inline

Honeyd Daemon

Mô phỏng hàng ngàn máy chủ và dịch vụ giả lập.
Nhận biết: Phản hồi giả mạo các yêu cầu SMTP/network với cấu trúc bất thường.

Sebek Honeypot

Bắt giam lệnh gọi hệ thống read() để ghi lại hoạt động độc hại.
Nhận biết: Gây ra độ trễ/tắc nghẽn mạng do truyền dữ liệu Sebek chưa mã hóa.

Snort_inline

Tự động sửa đổi hoặc loại bỏ gói tin đi.
Nhận biết: Bắt gói tin đi bằng một máy thứ hai để so sánh xem gói tin có bị sửa đổi/mất dấu hay không.

Phát hiện Fake AP và Honeypot Bait and Switch

Fake AP

Chỉ phát khung Beacon 802.11b với ESSID/BSSID ngẫu nhiên.
Nhận biết: Theo dõi lưu lượng mạng — Fake AP hoàn toàn không sinh ra lưu lượng dữ liệu thực tế.

Honeypot Bait and Switch

Tự động chuyển hướng toàn bộ lưu lượng của kẻ tấn công sang Honeypot ngay khi phát hiện xâm nhập.
Nhận biết: Phân tích sự thay đổi đột ngột của các tham số TCP/IP:
- RTT (Round Trip Time - Thời gian khứ hồi)
- TTL (Time to Live)
- TCP Timestamp

Các công cụ lẩn tránh IDS/Firewall phổ biến

Traffic IQ Professional:

Công cụ kiểm thử bảo mật chuyên nghiệp, tạo ra lưu lượng ứng dụng chuẩn hoặc lưu lượng tấn công giữa hai máy ảo.

Dùng để đánh giá hành vi của các thiết bị không phải Proxy (Firewall, IDS/IPS, Router, Switch).

Nguy cơ: Kẻ tấn công lợi dụng khả năng tạo lưu lượng tấn công tùy chỉnh để qua mặt thiết bị biên.



Các công cụ lẩn tránh IDS/Firewall phổ biến

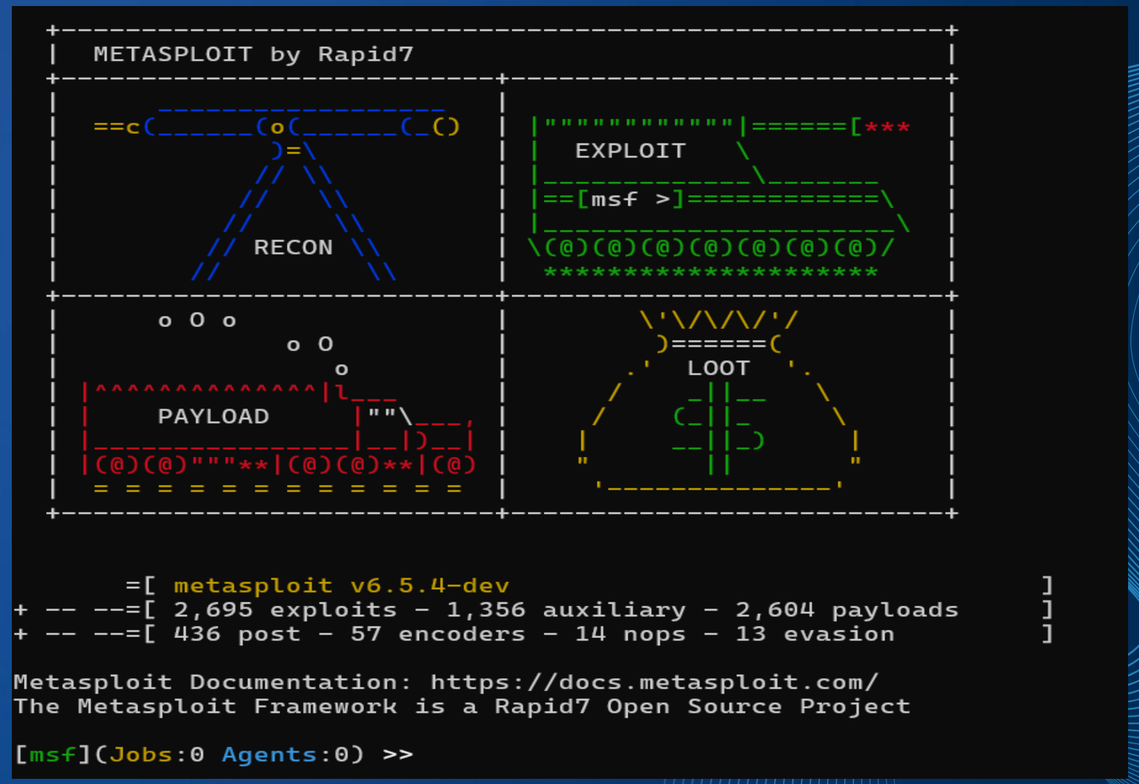
Các công cụ lẩn tránh khác:

Nmap: Quét cổng, dò quét lỗ hổng và hỗ trợ các script lẩn tránh (như firewalk).

Metasploit & Msfvenom: Framework khai thác lỗ hổng và mã hóa payload tránh so khớp chữ ký IDS.

Inundator & IDS-Evasion: Tự động hóa quá trình gửi lưu lượng gây tràn ngập hoặc tránh né IDS.

Hyperion: Mã hóa/xáo trộn file thực thi (crypter) để qua mặt cơ chế phát hiện.



Công cụ tạo mảnh gói tin

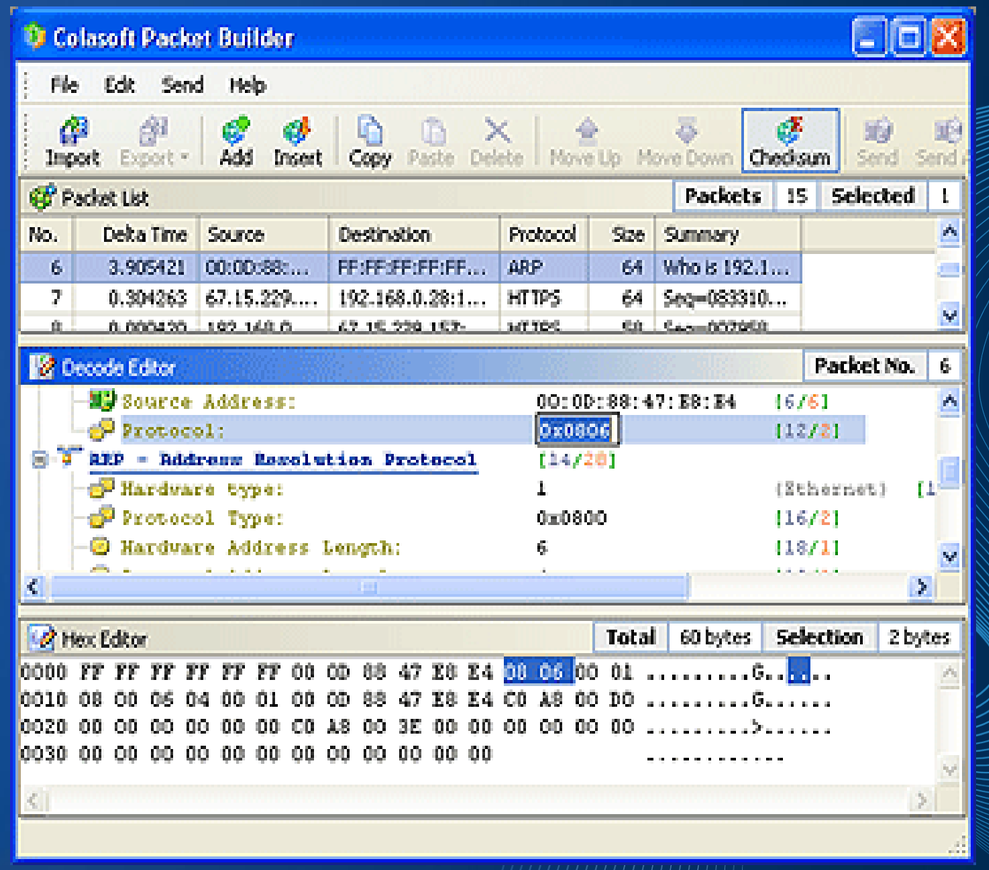
Mục đích: Kẻ tấn công sử dụng các công cụ để tạo các gói tin và chia nhỏ (phân mảnh) chúng nhằm qua mặt cơ chế kiểm tra chữ ký của Firewall/IDS.

Colasoft Packet Builder:

Tạo các gói tin mạng tùy chỉnh: Ethernet, ARP, IP, TCP, UDP.
Cho phép chỉnh sửa tiêu đề và phân mảnh gói tin theo ý muốn.

Các công cụ tạo/chỉnh sửa gói tin phổ biến khác:
CommView & NetScanTools Pro: Quét, phân tích và khởi tạo gói tin mạng.

Ostinato & WAN Killer: Trình tạo lưu lượng mạng dung lượng lớn.
WireEdit: Công cụ chỉnh sửa trực tiếp dữ liệu gói tin trong tệp pcap.



CÁC BIỆN PHÁP ĐỐI PHÓ VỚI LẨN TRÁNH IDS/FIREWALL

Phòng chống lẩn tránh IDS

Tối ưu hóa và chuẩn hóa lưu lượng

- Sử dụng giải pháp chuẩn hóa lưu lượng (Traffic Normalizer) trước khi dữ liệu tới IDS.
- Bắt buộc IDS ghép nối chính xác các gói phân mảnh theo đúng thứ tự và thời gian.

Củng cố cấu hình hệ thống

- Thay đổi/Chặn các gói ICMP TTL hết hạn ở biên; điều chỉnh TTL đồng nhất.
- Nhận diện pattern NOP khác $0x90$để chặn Shellcode đa hình.
- Kết hợp phát hiện dựa trên chữ ký (Signature) với phân tích hành vi/thống kê (Anomaly) để chống Zero-day.

Phòng chống Vượt qua Tường lửa

Nguyên tắc cấu hình Tường lửa:

- Default Deny: Từ chối tất cả lưu lượng theo mặc định, chỉ mở các dịch vụ tối cần thiết.
- Thiết lập lọc địa chỉ IP nguồn/đích và số cổng chặt chẽ; chặn kết nối FTP không dùng đến.

Giám sát & Kiểm tra định kỳ:

- Bật tính năng kiểm tra lưu lượng mã hóa HTTPS/TLS và App-ID để chặn ứng dụng ẩn danh.
- Đẩy Log ra máy chủ Syslog từ xa và kiểm tra log định kỳ.
- Sao lưu cấu hình, kiểm soát truy cập vật lý và thường xuyên quét đánh giá lỗ hổng quy tắc Firewall.

LAB DEMO:
ModSecurity trên Ubuntu 24.04

Q: ModSecurity là gì ?
A: Một tường lửa ứng dụng web (WAF) mã nguồn mở, được thiết kế để cung cấp các chức năng bảo mật và bảo vệ cho các ứng dụng web

Q: ModSecurity hoạt động như thế nào ?
A: Hoạt động bằng cách kiểm tra các yêu cầu HTTP gửi đến và phản hồi giữa trình duyệt và máy chủ để phát hiện và ngăn chặn các cuộc tấn công nhằm vào các lỗ hổng bảo mật trong ứng dụng web.

Q: ModSecurity có hoạt động thời gian thực không ?
A: ModSecurity hỗ trợ hoạt động trên thời gian thực, bao gồm theo dõi, giám sát, ghi lại nhật kí, chặn,…

Q: ModSecurity hỗ trợ trên các hệ điều hành nào ?
A: ModSecurity hỗ trợ đa nền tảng, bao gồm triển khai trên Linux, MacOS, FreeBSD,…, nhưng đa số hoạt động trên Linux



3 chế độ cấu hình của WAF ModSecurity

Chế độ	Xử lí
Detection Only	Phát hiện và ghi nhật ký nhưng không chặn request
On	Chặn nếu như khớp với quy tắc
Off	Tắt thực thi quy tắc

4 cấp độ lọc của OWASP CRS — Paranoia Level

Paranoia Level (PL)	Đặc điểm kĩ thuật	Nhược điểm
PL1	Các quy tắc phổ biến, ít hoặc không gây ảnh hưởng đến request hợp lệ	Ít false positive hơn, phù hợp khởi đầu
PL2	Kiểm tra chặt chẽ hơn, bổ sung các mẫu tấn công và trường hợp phức tạp với PL1	Có thể phát hiện thêm tấn công nhưng sẽ tăng nguy cơ cảnh báo nhầm so với PL1
PL3	Kiểm tra nghiêm ngặt, sử dụng nhiều quy tắc nhạy hơn so với PL2	Cần tinh chỉnh thật kĩ theo ứng dụng web, nguy cơ cảnh báo nhầm cao hơn mức PL2
PL4	Mức kiểm tra rất nghiêm ngặt, bao gồm nhiều mẫu có thể trùng với dữ liệu hợp lệ	Nguy cơ false positive cao hơn cao hơn hẳn so mức PL3

5 hành động (Actions) của quy tắc

Nhóm	Chức năng	Hành động
Disruptive actions	Tác động đến giao dịch HTTP hoặc luồng xử lý	deny, allow, pass, block, drop, redirect
Non-disruptive actions	Thực hiện chức năng mà không trực tiếp thay đổi luồng xử lý quy tắc	log, nolog, setvar, capture, ctl
Flow actions	Điều khiển thứ tự thực thi quy tắc	chain, skip, skipAfter
Metadata actions	Cung cấp thông tin mô tả và phân loại quy tắc	id, rev, msg, severity, tag, phase
Data actions	Cung cấp giá trị dữ liệu cho các hành động khác	status, logdata

Thiết lập WAF ModSecurity trên Ubuntu 24.04 với Docker

Hệ điều hành: Ubuntu 24.04 LTS

Tường lửa ứng dụng web: ModSecurity

Nền tảng triển khai: Docker

Bộ quy tắc: OWASP Core Rule Set (CRS)

Đối tượng bảo vệ: Website thử nghiệm chứa 03 lỗ hổng bảo mật

Phương pháp đánh giá: Gửi các request thử nghiệm, so sánh kết quả trước và sau khi kích hoạt WAF, kiểm tra HTTP response và log WAF

Triển khai các kịch bản tấn công
Kịch bản 1: phát hiện, ghi nhận, chặn tấn công SQL injection

Triển khai các kịch bản tấn công
Kịch bản 2: phát hiện, ghi nhận, chặn tấn công XSS Store

Triển khai các kịch bản tấn công
Kịch bản 3: phát hiện, ghi nhận, chặn tấn công Path Traversal

CẢM ƠN ĐÃ THEO DÕI!